

TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
ĐẠI HỌC QUỐC GIA TP. HỒ CHÍ MINH

[Trường ĐHKHTN — Logo
Placeholder]

Linux Capstone

Hệ điều hành Linux & Ứng dụng

Sinh viên thực hiện:	Nguyễn Lê Nhật Duy	23127180
	Lê Nguyễn Nhật Khánh	23127206
	Lê Hoàng Long	23127412
	Nguyễn Văn Bảo Phúc	23127457
	Cao Lê Gia Phú	23127535

Thành viên và phân công

STT	Họ và tên	Phân công thực tế	Mức đóng góp
1	Cao Lê Gia Phú	hạ tầng và mạng	100%
2	Nguyễn Văn Bảo Phúc	reverse proxy và bảo mật web	100%
3	Nguyễn Lê Nhật Duy	ứng dụng và systemd	100%
4	Lê Nguyễn Nhật Khánh	CSDL và sao lưu	100%
5	Lê Hoàng Long	bộ công cụ tự động hóa và cảnh báo	100%

Mục lục

1	Tổng quan hệ thống	4
1.1	Hướng đồ án đã chọn	4
1.2	Sơ đồ mạng và các máy ảo (VM)	4
1.3	Cấu hình lưu trữ phần cứng	6
1.4	Giải pháp truy cập quản trị từ xa (SSH ProxyJump)	6
2	Các bước xây dựng hệ thống	7
2.1	Cài đặt các gói phần mềm cần thiết	7
2.2	Khởi tạo tài khoản quản trị viên	7
2.3	Cấu hình Nginx Virtual Hosts	7
2.3.1	Virtual Host 1: Reverse Proxy trở đến Backend Application (app.conf)	7
2.3.2	Virtual Host 2: Trang trạng thái tĩnh (status.conf)	8
2.4	Cấu hình ứng dụng và Cơ sở dữ liệu	8
2.4.1	Cấu hình dịch vụ systemd cho Backend (myapp.service)	8
2.4.2	Cấu hình Cơ sở dữ liệu MySQL	9
2.4.3	Mã nguồn ứng dụng Backend	9
3	Gia cố bảo mật	10
3.1	Cấu hình tường lửa UFW	10
3.2	Gia cố dịch vụ SSH	10
3.3	Khắc phục lỗi ghi đè của cloud-init	10
3.4	Brute-force Protection (fail2ban)	11
3.5	Giám sát hệ thống (auditd)	11
3.6	Đánh giá an toàn hệ thống (Lynis)	11
4	Sao lưu & Khôi phục	13
4.1	Chiến lược sao lưu tự động	13
4.2	Cấu hình lập lịch sao lưu và quy trình khôi phục	13
4.2.1	Cấu hình các tệp chứa biến môi trường	13
4.2.2	Các tập lệnh sao lưu và khôi phục CSDL	14
4.2.3	Các tập lệnh sao lưu và khôi phục toàn diện đa tầng	15
4.2.4	Cấu hình lập lịch tự động hóa bằng Cron	18
4.2.5	Diễn tập thực tế khôi phục thảm họa CSDL	19
5	Tự động hóa	20
5.1	Script cấu hình tường lửa UFW (ufw_setup.sh)	20
5.2	Script mô phỏng dò mật khẩu SSH (simulate_ssh_bruteforce.sh)	20
5.3	Các script tự động hóa khác trong hệ thống	20
5.3.1	Thư viện gửi cảnh báo Telegram (lib/alert.sh)	21
5.3.2	Script giám sát sức khỏe hệ thống và dịch vụ (healthcheck.sh)	21
5.3.3	Script triển khai an toàn có tự động Rollback (deploy.sh)	23
5.3.4	Script xoay vòng và nén nhật ký (logrotate.sh)	25
5.3.5	Menu CLI điều phối tương tác hệ thống (main.sh)	26
5.3.6	Kịch bản kiểm thử các tính năng tự động hóa	27
6	Điểm thưởng TLS / HTTPS	29
6.1	Lập luận khoa học về chứng chỉ tự ký trên môi trường Lab	29

6.2	Các bước tạo chứng chỉ tự ký và cấu hình Nginx	29
7	Nhìn lại	31
7.1	Bài học từ sự cố cloud-init	31
7.2	Kế hoạch cải tiến và Bài học khác	31

1 Tổng quan hệ thống

Hướng đồ án đã chọn

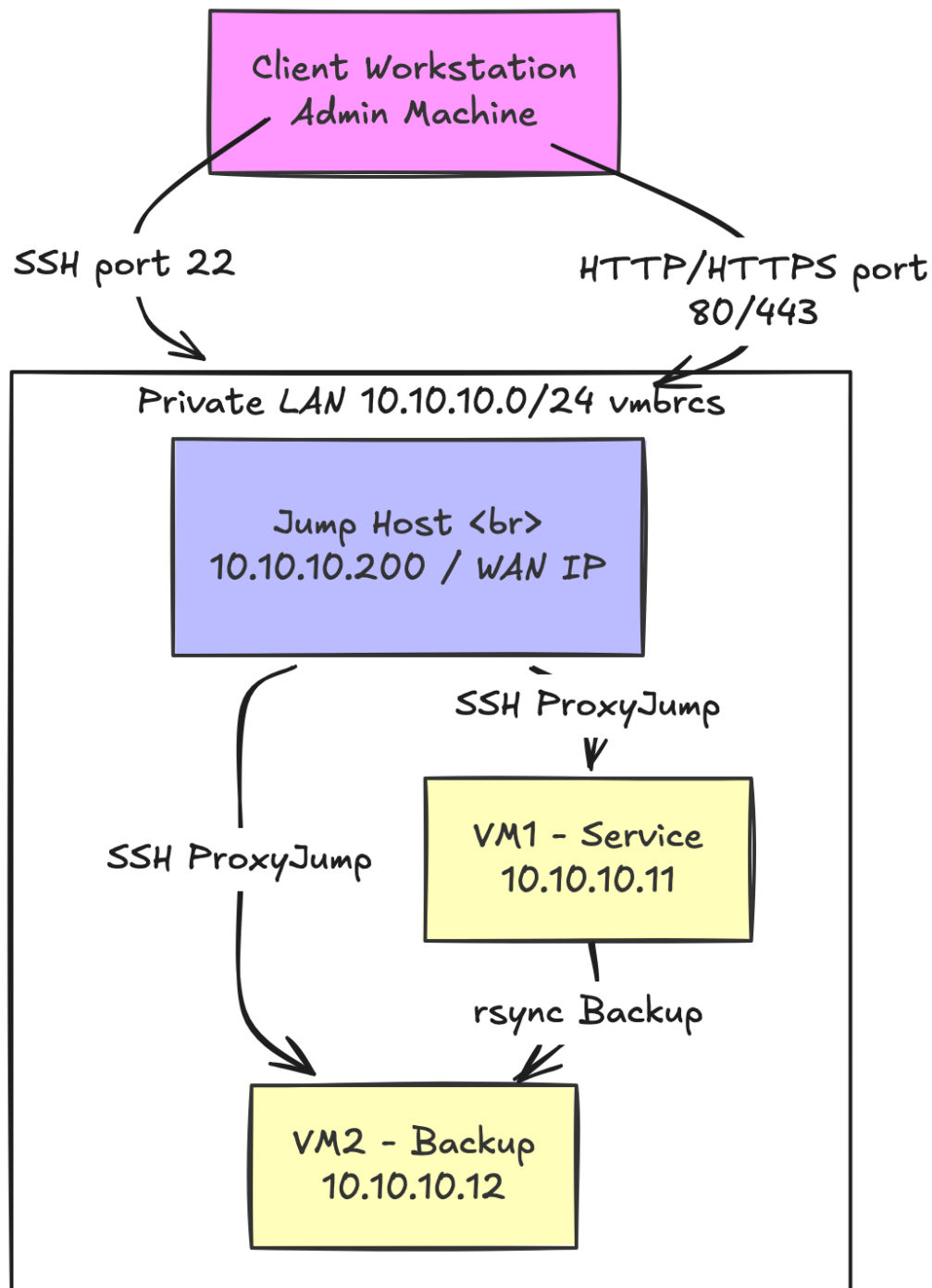
Dự án Capstone triển khai hệ thống bao gồm một ứng dụng Web Backend (FastAPI), cơ sở dữ liệu MySQL, và Nginx làm Web Server kiêm Reverse Proxy. Toàn bộ kiến trúc được triển khai trên nền tảng ảo hóa Proxmox Virtual Environment (PVE) và hệ điều hành Ubuntu 22.04 LTS Server.

Sơ đồ mạng và các máy ảo (VM)

Hệ thống được thiết kế theo mô hình phân vùng mạng an toàn, cô lập máy dịch vụ chính và máy sao lưu khỏi internet bên ngoài bằng cách sử dụng cổng trung chuyển (Jump Host / Bastion Host):

1. **Mạng ngoài (External/WAN - Bridge vmbr0):** Liên kết trực tiếp card vật lý trên máy chủ Proxmox, cung cấp IP mạng ngoài cho máy ảo `jump-host` để quản trị viên có thể kết nối từ xa.
2. **Mạng LAN nội bộ (Private LAN - Bridge vmbrcs):** Switch ảo cô lập hoàn toàn (không gắn cổng mạng vật lý). Sử dụng dải IP nội bộ `10.10.10.0/24` với Gateway ảo trên Host PVE là `10.10.10.1`.

Sơ đồ kết nối hệ thống được mô tả ở hình dưới đây:



Hình 1: Sơ đồ kiến trúc kết nối mạng an toàn của hệ thống

Danh sách các máy ảo được cấu hình và vận hành đồng thời trên node Proxmox:

ID VM	Hostname	vCPU	RAM	Dải IP kết nối	Vai trò hệ thống
200	jump-host	1	1.00 GiB	WAN (Bridge vmbrcs) 10.10.10.200 (vmbrcs)	Cổng SSH Jump Host (Bastion) trung chuyển
203	vm1-svc	2	2.00 GiB	10.10.10.11 (vmbrcs)	Máy chủ dịch vụ chính (Nginx, App, MySQL)

202	vm2-backup	2	2.00 GiB	10.10.10.12 (vmbrcs)	Máy chủ nhận và lưu trữ bản sao lưu
-----	------------	---	----------	-------------------------	--

Cấu hình lưu trữ phần cứng

- **jump-host**: Sử dụng 1 ổ cứng ảo `scsi0` (20 GB) chứa HDH.
- **vm1-svc**: Sử dụng 2 ổ cứng ảo:
 - `scsi0` (20 GB): Chứa hệ điều hành Ubuntu Server.
 - `scsi1` (10 GB): Định dạng `ext4`, mount tự động qua `/etc/fstab` vào thư mục `/mnt/data`. Đây là phân vùng độc lập lưu trữ MySQL và mã nguồn ứng dụng, giúp bảo vệ dữ liệu dự án tách biệt khỏi phân vùng HDH.
- **vm2-backup**: Sử dụng 2 ổ cứng ảo:
 - `scsi0` (20 GB): Chứa hệ điều hành Ubuntu Server.
 - `scsi1` (20 GB): Định dạng `ext4`, mount tự động qua `/etc/fstab` vào thư mục `/mnt/backup` chuyên dụng cho lưu trữ bản sao lưu và quản lý xoay vòng.

Giải pháp truy cập quản trị từ xa (SSH ProxyJump)

Vì `vm1-svc` và `vm2-backup` nằm trong mạng nội bộ riêng tư `vmbrcs`, quản trị viên không thể SSH trực tiếp. Giải pháp SSH ProxyJump được thiết lập như sau:

1. Đăng nhập bằng khóa SSH Ed25519 từ máy Client cá nhân. Tắt đăng nhập bằng mật khẩu (`PasswordAuthentication no`) và tài khoản root (`PermitRootLogin no`) trên tất cả các VM.
2. Cấu hình file SSH Client trên máy quản trị (`/.ssh/config`) để tạo kết nối trong suốt:

```

1 Host jump
2     HostName <IP_JUMP_HOST_WAN>
3     User sysadmin
4     IdentityFile ~/.ssh/id_ed25519
5
6 Host vm1-svc
7     HostName 10.10.10.11
8     User sysadmin
9     ProxyJump jump
10    IdentityFile ~/.ssh/id_ed25519
11
12 Host vm2-backup
13    HostName 10.10.10.12
14    User sysadmin
15    ProxyJump jump
16    IdentityFile ~/.ssh/id_ed25519

```

3. Lệnh để SSH trực tiếp vào máy chủ dịch vụ thông qua Jump Host:

```

1 ssh vm1-svc
2

```

2 Các bước xây dựng hệ thống

Cài đặt các gói phần mềm cần thiết

Trên máy chủ dịch vụ vm1-svc, thực hiện cài đặt các công cụ và dịch vụ cốt lõi:

```
1 sudo apt update
2 sudo apt install -y nginx ufw fail2ban auditd audispd-plugins lynis
   openssl curl sshpass
```

Khởi tạo tài khoản quản trị viên

Khởi tạo các tài khoản có quyền quản trị qua sudo thay cho tài khoản root:

```
1 # Tao user sysadmin va dat mat khau
2 useradd -m -s /bin/bash sysadmin
3 passwd sysadmin
4 usermod -aG sudo sysadmin
5
6 # Tao user devops va dat mat khau
7 useradd -m -s /bin/bash devops
8 passwd devops
9 usermod -aG sudo devops
```

Import Public Key từ máy Client quản trị vào tệp authorized_keys của các user trên vm1-svc:

```
1 # Cho sysadmin
2 mkdir -p /home/sysadmin/.ssh
3 cat >> /home/sysadmin/.ssh/authorized_keys << 'EOF'
4 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGx7k3... sysadmin@capstone-svc01
5 EOF
6 chmod 700 /home/sysadmin/.ssh
7 chmod 600 /home/sysadmin/.ssh/authorized_keys
8 chown -R sysadmin:sysadmin /home/sysadmin/.ssh
9
10 # Cho devops
11 mkdir -p /home/devops/.ssh
12 cat >> /home/devops/.ssh/authorized_keys << 'EOF'
13 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGx7k3... sysadmin@capstone-svc01
14 EOF
15 chmod 700 /home/devops/.ssh
16 chmod 600 /home/devops/.ssh/authorized_keys
17 chown -R devops:devops /home/devops/.ssh
```

Cấu hình Nginx Virtual Hosts

Hệ thống cấu hình ≥ 2 virtual hosts trên Nginx nhằm đáp ứng yêu cầu phân chia dịch vụ.

Virtual Host 1: Reverse Proxy trở đến Backend Application (app.conf)

Cấu hình trở tới ứng dụng FastAPI đang chạy nội bộ tại cổng 8000:

```
1 # /etc/nginx/sites-available/app.conf
2 server {
3     listen 80;
4     server_name app.lab.local;
```



```

5
6     access_log /var/log/nginx/app.access.log;
7     error_log /var/log/nginx/app.error.log;
8
9     location / {
10         proxy_pass http://127.0.0.1:8000;
11         proxy_set_header Host $host;
12         proxy_set_header X-Real-IP $remote_addr;
13         proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
14         proxy_set_header X-Forwarded-Proto $scheme;
15     }
16 }

```

Virtual Host 2: Trang trạng thái tĩnh (status.conf)

Cấu hình phục vụ trang trạng thái tĩnh của hệ thống tại thư mục /var/www/status:

```

1 # /etc/nginx/sites-available/status.conf
2 server {
3     listen 80;
4     server_name status.lab.local;
5
6     root /var/www/status;
7     index index.html;
8
9     access_log /var/log/nginx/status.access.log;
10    error_log /var/log/nginx/status.error.log;
11
12    location / {
13        try_files $uri $uri/ =404;
14    }
15 }

```

Trang web tĩnh tại /var/www/status/index.html được khởi tạo như sau:

```

1 <!DOCTYPE html>
2 <html lang="vi">
3 <head>
4 <meta charset="UTF-8">
5 <title>Trang thai he thong - Capstone</title>
6 <style>
7     body { font-family: sans-serif; background:#0d1117; color:#c9d1d9; padding:2rem; }
8     h1 { color:#58a6ff; }
9     .ok { color:#3fb950; font-weight:bold; }
10 </style>
11 </head>
12 <body>
13 <h1>Capstone System Status</h1>
14 <p>Vhost 2 - trang trang thai tinh phục vụ bởi Nginx.</p>
15 <p>Trang thai web server: <span class="ok">ONLINE</span></p>
16 <p>Xem chi tiết dịch vụ qua bộ công cụ health-check (scripts/healthcheck.sh).</p>
17 </body>
18 </html>

```

Kích hoạt các cấu hình và reload Nginx:

```

1 ln -s /etc/nginx/sites-available/app.conf /etc/nginx/sites-enabled/
2 ln -s /etc/nginx/sites-available/status.conf /etc/nginx/sites-enabled/
3 rm -f /etc/nginx/sites-enabled/default
4
5 nginx -t
6 systemctl reload nginx

```

Cấu hình ứng dụng và Cơ sở dữ liệu

Cấu hình dịch vụ systemd cho Backend (myapp.service)

Ứng dụng Backend (myapp) được quản lý tự động thông qua systemd service:

```

1 # /etc/systemd/system/myapp.service
2 [Unit]
3 Description=MyApp FastAPI Application Service
4 After=network.target mysql.service
5
6 [Service]
7 Type=simple
8 User=myapp
9 WorkingDirectory=/mnt/data/myapp
10 EnvironmentFile=/etc/myapp/myapp.env
11 ExecStart=/usr/local/bin/uvicorn main:app --host 127.0.0.1 --port 8000
12 Restart=on-failure
13 RestartSec=5
14 StandardOutput=journal
15 StandardError=journal
16
17 [Install]
18 WantedBy=multi-user.target

```

Bí mật kết nối được khai báo trong `/etc/myapp/myapp.env` với quyền hạn chế:

```

1 # Quyền file: -rw-r----- 1 root myapp
2 DB_PASSWORD=<mat_khau_csdl_thuc_te>
3 DB_USER=app_user
4 DB_NAME=app_db

```

Cấu hình Cơ sở dữ liệu MySQL

Cơ sở dữ liệu MySQL được cấu hình với đặc quyền tối thiểu và chỉ cho phép nghe tại localhost:

1. File cấu hình MySQL được điều chỉnh để bind địa chỉ:

```

1 bind-address = 127.0.0.1
2

```

Chứng minh bằng lệnh `ss -tlnp`: cơ sở dữ liệu MySQL (3306) chỉ lắng nghe trên 127.0.0.1.

2. Tài khoản `app_user` được phân quyền tối thiểu để thao tác trên database `app_db`:

```

1 GRANT SELECT, INSERT, UPDATE, DELETE ON app_db.* TO 'app_user'@'
   localhost';
2 FLUSH PRIVILEGES;
3

```

Mã nguồn ứng dụng Backend

*[Chưa có mã nguồn ứng dụng Backend FastAPI/Flask trong tài liệu đầu vào
- Placeholder]*

3 Gia cố bảo mật

Cấu hình tường lửa UFW

Tường lửa UFW được thiết lập với chính sách mặc định chặn toàn bộ kết nối đi vào và chỉ cho phép các cổng dịch vụ cần thiết:

- **Cổng 22/tcp:** Phục vụ quản trị hệ thống từ xa qua SSH từ Jump Host.
- **Cổng 80/tcp:** Phục vụ Nginx nhận truy cập Web HTTP (redirect sang HTTPS).
- **Cổng 443/tcp:** Phục vụ Nginx nhận truy cập Web bảo mật HTTPS.
- Các cổng nội bộ **8000 (FastAPI)** và **3306 (MySQL)** bị chặn hoàn toàn từ bên ngoài, chỉ lắng nghe ở 127.0.0.1.

Chi tiết cấu hình tường lửa nằm ở tệp `/root/ufw_setup.sh` (mã nguồn xem tại Mục 5).

Gia cố dịch vụ SSH

Tệp cấu hình dịch vụ SSH tại `/etc/ssh/sshd_config` được gia cố bằng cách bổ sung các tham số bảo mật cao:

```
1 PermitRootLogin no
2 PasswordAuthentication no
3 PubkeyAuthentication yes
4 AllowUsers sysadmin devops
5 MaxAuthTries 3
6 ClientAliveInterval 300
7 ClientAliveCountMax 2
8 X11Forwarding no
```

Đánh đổi: Việc tắt `PasswordAuthentication` giúp chống lại hoàn toàn các cuộc tấn công brute-force mật khẩu SSH, tuy nhiên yêu cầu quản trị viên bắt buộc phải có khóa SSH Ed25519 tương ứng thì mới có thể truy cập hệ thống.

Khắc phục lỗi ghi đè của cloud-init

Vấn đề xảy ra: Trên môi trường VM khởi tạo từ cloud image trên Proxmox, file cấu hình `/etc/ssh/sshd_config.d/50-cloud-init.conf` tự động sinh và chứa tham số `PasswordAuthentication yes`. Do cơ chế đọc file của SSH, file trong thư mục `sshd_config.d/` được nạp trước và ghi đè cấu hình bảo mật no trong file chính `sshd_config`.

Giải pháp khắc phục:

```
1 # Xóa file override của cloud-init
2 sudo rm /etc/ssh/sshd_config.d/50-cloud-init.conf
3
4 # Chặn cloud-init tự sinh lại ở lần boot sau
5 mkdir -p /etc/cloud/cloud.cfg.d
6 echo "ssh_pwauth: false" > /etc/cloud/cloud.cfg.d/99-disable-ssh-pwauth.
   cfg
7
8 # Reload và kiểm tra lại
9 sudo sshd -t
10 sudo sshd -T | grep -i passwordauthentication # Kỳ vọng ra "no"
11 sudo systemctl restart ssh
```

Brute-force Protection (fail2ban)

fail2ban được triển khai để bảo vệ dịch vụ SSH khỏi dò mật khẩu thông qua cấu hình trong tệp `/etc/fail2ban/jail.local`:

```
1 # /etc/fail2ban/jail.local
2 [DEFAULT]
3 bantime = 600
4 findtime = 300
5 maxretry = 3
6 backend = systemd
7
8 [sshd]
9 enabled = true
10 port = ssh
11 logpath = %(sshd_log)s
12 maxretry = 3
13 bantime = 600
```

Script kiểm thử mô phỏng tấn công từ VM2 (`simulate_ssh_bruteforce.sh`) được trình bày cụ thể ở Mục 5. Khi thực hiện SSH sai 4 lần liên tiếp, fail2ban sẽ tự động chặn IP của VM2. Kiểm tra trạng thái bằng lệnh:

```
1 sudo fail2ban-client status sshd
```

Giám sát hệ thống (auditd)

Cấu hình auditd theo dõi chặt chẽ mọi hành vi thay đổi đối với hai tệp tin nhạy cảm của hệ thống: `/etc/passwd` và `/etc/shadow`. Nội dung quy luật kiểm toán tại `/etc/audit/rules.d/capstone.rules`:

```
1 -w /etc/passwd -p wa -k capstone_passwd_watch
2 -w /etc/shadow -p wa -k capstone_shadow_watch
```

Áp dụng cấu hình và kiểm tra:

```
1 sudo augenrules --load
2 sudo systemctl restart auditd
3 sudo auditctl -l
```

Để tra cứu dấu vết kiểm toán khi có sự thay đổi (ví dụ khi thêm/xóa user):

```
1 ausearch -k capstone_passwd_watch -ts recent
```

Đánh giá an toàn hệ thống (Lynis)

Thực hiện đánh giá bảo mật thông qua công cụ Lynis:

```
1 sudo lynis audit system
```

Để tăng điểm chỉ số Hardening Index, 3 mục kiến nghị sau đã được khắc phục thủ công trên `vm1-svc`:

1. Cấu hình thời gian hiệu lực mật khẩu (`/etc/login.defs`):

```
1 sudo sed -i 's/^PASS_MAX_DAYS.*/PASS_MAX_DAYS 90/' /etc/login.
  defs
2 sudo sed -i 's/^PASS_MIN_DAYS.*/PASS_MIN_DAYS 7/' /etc/login.
  defs
3
```

2. Thêm Banner cảnh báo khi truy cập SSH:

```
1 echo "Authorized access only. All activity is monitored." | sudo  
  tee /etc/issue.net  
2 echo 'Banner /etc/issue.net' | sudo tee -a /etc/ssh/sshd_config  
3 sudo systemctl restart ssh  
4
```

3. Vô hiệu hóa giao thức IPv6 không sử dụng:

```
1 echo "net.ipv6.conf.all.disable_ipv6 = 1" | sudo tee -a /etc/  
  sysctl.conf  
2 echo "net.ipv6.conf.default.disable_ipv6 = 1" | sudo tee -a /etc/  
  sysctl.conf  
3 sudo sysctl -p  
4
```

4 Sao lưu & Khôi phục

Chiến lược sao lưu tự động

Chiến lược sao lưu của hệ thống **Mini Vault** được thiết kế theo mô hình 3-2-1 bao gồm:

1. Thực hiện sao lưu định kỳ cơ sở dữ liệu MySQL thông qua lệnh `mysqldump` kết hợp với việc nén và đóng gói toàn bộ thư mục chứa dữ liệu tĩnh hoặc mã nguồn ứng dụng web tại `/var/www/status` và mã nguồn FastAPI.
2. Các bản sao lưu được nén dưới định dạng `.tar.gz` và gắn nhãn thời gian tương ứng để dễ dàng phân biệt.
3. Thực hiện đồng bộ hóa bản sao lưu từ `vm1-svc` sang máy chủ lưu trữ chuyên dụng `vm2-backup` (`10.10.10.12`) thông qua giao thức SSH bảo mật và công cụ `rsync`.
4. Áp dụng chính sách lưu giữ (Retention Policy) tự động xóa các bản sao lưu cũ quá 7 ngày để giải phóng tài nguyên lưu trữ của đĩa ảo `scsi1`.

Cấu hình lập lịch sao lưu và quy trình khôi phục

Quy trình sao lưu và khôi phục của hệ thống được hiện thực hóa qua các bước cấu hình biến môi trường, thiết lập các script chuyên biệt và lập lịch định kỳ qua cron.

Cấu hình các tệp chứa biến môi trường

Các tệp cấu hình chứa thông tin nhạy cảm được bảo mật nghiêm ngặt bằng quyền truy cập tối thiểu:

1. Tệp `/etc/db_backup.env` lưu trữ thông tin kết nối MySQL và chính sách lưu giữ (chỉ cho phép nhóm `sysadmin` và `root` đọc, quyền 640):

```
1 # /etc/db_backup.env
2 DB_HOST="127.0.0.1"
3 DB_PORT="3306"
4 DB_NAME="app_db"
5 DB_USER="app_user"
6 DB_PASS="<DB_PASSWORD>"
7 BACKUP_DIR="/mnt/backup_data/db"
8 RETENTION_DAYS="7"
9
```

2. Tệp cấu hình chung của bộ công cụ vận hành `/home/sysadmin/ops-tool/config.env` (quyền 600 cho user `sysadmin`):

```
1 # /home/sysadmin/ops-tool/config.env
2 export TELEGRAM_BOT_TOKEN="<TELEGRAM_BOT_TOKEN>"
3 export TELEGRAM_CHAT_ID="<TELEGRAM_CHAT_ID>"
4 export THRESHOLD_CPU=80
5 export THRESHOLD_DISK=80
6 export THRESHOLD_RAM=85
7 export BACKUP_LOCAL_DIR="/data/backups"
8 export BACKUP_REMOTE_HOST="10.10.10.12"
9 export BACKUP_REMOTE_USER="vmbackup"
10 export BACKUP_REMOTE_DIR="/home/vmbackup/backups"
11 export BACKUP_RETENTION_DAYS=7
12 export TZ="Asia/Ho_Chi_Minh"
13
```

Các tập lệnh sao lưu và khôi phục CSDL

1. **Script sao lưu CSDL (db_backup.sh):** Thực hiện dump CSDL MySQL, nén luồng qua gzip, gắn nhãn thời gian và tự động dọn dẹp các bản sao lưu cũ quá 7 ngày:

```

1 #!/usr/bin/env bash
2 # db_backup.sh - Sao lưu CSDL MySQL nén luồng và áp dụng Retention Policy
3 set -euo pipefail
4
5 ENV_FILE="/etc/db_backup.env"
6 if [[ ! -f "${ENV_FILE}" ]]; then
7     echo "[ERROR] Không tìm thấy file cấu hình môi trường: ${ENV_FILE}" >&2
8     exit 1
9 fi
10
11 # Load biến môi trường
12 # shellcheck source=/dev/null
13 source "${ENV_FILE}"
14
15 TIMESTAMP=$(date +"%Y%m%d_%H%M%S")
16 BACKUP_FILE="${BACKUP_DIR}/${DB_NAME}_${TIMESTAMP}.sql.gz"
17
18 cleanup_on_error() {
19     echo "[ERROR] Quá trình sao lưu CSDL thất bại! Đang dọn dẹp..." >&2
20     if [[ -f "${BACKUP_FILE}" ]]; then
21         rm -f "${BACKUP_FILE}"
22     fi
23     exit 1
24 }
25
26 trap cleanup_on_error ERR
27
28 mkdir -p "${BACKUP_DIR}"
29
30 echo "[INFO] Đang tiến hành sao lưu CSDL '${DB_NAME}'..."
31 MYSQL_PWD="${DB_PASS}" mysqldump -h"${DB_HOST}" -P"${DB_PORT}" -u"${DB_USER}" --no-
    tablespaces "${DB_NAME}" | gzip > "${BACKUP_FILE}"
32
33 echo "[SUCCESS] Đã tạo bản sao lưu thành công: ${BACKUP_FILE}"
34 echo "[INFO] Đang dọn dẹp các bản sao lưu cũ hơn ${RETENTION_DAYS} ngày..."
35 find "${BACKUP_DIR}" -type f -name "${DB_NAME}*.sql.gz" -mtime +"${RETENTION_DAYS}"
    -delete
36 echo "[INFO] Hoàn tất quy trình sao lưu!"
37

```

2. **Script khôi phục CSDL (db_restore.sh):** Khôi phục CSDL MySQL trực tiếp từ tệp tin nén .sql.gz:

```

1 #!/usr/bin/env bash
2 # db_restore.sh - Khôi phục CSDL MySQL trực tiếp từ bản sao lưu nén
3 set -euo pipefail
4
5 ENV_FILE="/etc/db_backup.env"
6 if [[ ! -f "${ENV_FILE}" ]]; then
7     echo "[ERROR] Không tìm thấy file cấu hình môi trường: ${ENV_FILE}" >&2
8     exit 1
9 fi
10
11 # Load biến môi trường
12 # shellcheck source=/dev/null
13 source "${ENV_FILE}"
14
15 LATEST_BACKUP=$(find "${BACKUP_DIR}" -maxdepth 1 -name "${DB_NAME}*.sql.gz" -
    printf "%T@ %p\n" 2>/dev/null | sort -nr | head -n 1 | cut -d' ' -f2-)
16 RESTORE_FILE="${1:-${LATEST_BACKUP}}"
17
18 if [[ -z "${RESTORE_FILE}" || ! -f "${RESTORE_FILE}" ]]; then
19     echo "[ERROR] Không tìm thấy file sao lưu hợp lệ để khôi phục!" >&2
20     echo "Cú pháp: $0 [/đường/dẫn/file_backup.sql.gz]" >&2
21     exit 1
22 fi
23
24 cleanup_on_error() {

```

```

25     echo "[ERROR] Qua trình khôi phục CSDL thất bại!" >&2
26     exit 1
27 }
28
29 trap cleanup_on_error ERR
30
31 echo "[INFO] Đang tiến hành khôi phục CSDL '${DB_NAME}' từ file '${RESTORE_FILE}'..."
32 gunzip -c "${RESTORE_FILE}" | MYSQL_PWD="${DB_PASS}" mysql -h"${DB_HOST}" -P"${DB_PORT}" -u"${DB_USER}" "${DB_NAME}"
33
34 echo "[SUCCESS] Khôi phục dữ liệu thành công cho database '${DB_NAME}'!"
35

```

Các tập lệnh sao lưu và khôi phục toàn diện đa tầng

Để sao lưu và khôi phục toàn bộ các cấu hình hệ thống khác (Nginx, TLS keys, website data, myapp code, myapp.env), bộ công cụ sử dụng các script:

1. **Script sao lưu toàn diện và đồng bộ rsync (backup.sh):** Tự động gọi script sao lưu CSDL, thu thập mã nguồn, tệp cấu hình Nginx, chứng chỉ TLS, nén toàn bộ thành tệp .tar.gz, sau đó sử dụng rsync qua SSH Key không mật khẩu đẩy sang máy chủ vm2-backup (10.10.10.12):

```

1  #!/usr/bin/env bash
2  # backup.sh - Sao lưu toàn diện đa tầng và đồng bộ rsync sang VM2
3  set -euo pipefail
4
5  BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")/.." && pwd)"
6  # shellcheck source=/dev/null
7  source "${BASE_DIR}/config.env"
8  # shellcheck source=/dev/null
9  source "${BASE_DIR}/lib/alert.sh"
10
11 LOG_FILE="${BASE_DIR}/logs/backup.log"
12 mkdir -p "$(dirname "$LOG_FILE")"
13
14 cleanup_on_err() {
15     local exit_code=$?
16     local line_no=$1
17     local err_msg="[ALERT] [VM1] Backup THAT BAI tai dong ${line_no} (Exit: ${exit_code})"
18     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [FATAL] ${err_msg}" | tee -a "$LOG_FILE"
19     send_telegram_alert "${err_msg}"
20 }
21 trap 'cleanup_on_err ${LINENO}' ERR
22
23 log_msg() {
24     local level="$1"
25     local message="$2"
26     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [${level}] ${message}" | tee -a "$LOG_FILE"
27 }
28
29 log_msg "INFO" "=== BAT DAU QUY TRINH SAO LUU TOAN DIEN ==="
30 TIMESTAMP="$(date '+%Y%m%d_%H%M%S')"
31 BACKUP_NAME="backup_${TIMESTAMP}"
32 TEMP_BACKUP_DIR="/tmp/${BACKUP_NAME}"
33 ARCHIVE_FILE="${BACKUP_LOCAL_DIR}/${BACKUP_NAME}.tar.gz"
34
35 sudo rm -rf "$TEMP_BACKUP_DIR"
36 mkdir -p "$TEMP_BACKUP_DIR"
37 sudo mkdir -p "$BACKUP_LOCAL_DIR"
38 sudo chown -R sysadmin:sysadmin "$BACKUP_LOCAL_DIR"
39
40 # 1. Goi script dump CSDL (Tang DB)
41 mkdir -p "${TEMP_BACKUP_DIR}/database"
42 DB_SCRIPT="/home/sysadmin/scripts/scripts_backup_restore_DB/db_backup.sh"
43 if [[ -f "$DB_SCRIPT" ]]; then
44     log_msg "INFO" "Kich hoạt script sao lưu CSDL..."
45     sudo bash "$DB_SCRIPT"
46     if [[ -f "/etc/db_backup.env" ]]; then

```



```

47     source "/etc/db_backup.env"
48     LATEST_SQL=$(find "${BACKUP_DIR}" -maxdepth 1 -name "${DB_NAME}*.sql.gz" -
printf "%T@ %p\n" | sort -nr | head -n 1 | cut -d' ' -f2-)
49     if [[ -n "$LATEST_SQL" ]] && -f "$LATEST_SQL" ]]; then
50         cp "$LATEST_SQL" "${TEMP_BACKUP_DIR}/database/"
51         log_msg "INFO" "Đã đưa bản dump DB ($(basename "$LATEST_SQL")) vào gói
sao lưu."
52     fi
53 fi
54 fi
55
56 # 2. Sao lưu mã nguồn app, secrets và systemd (Tang App)
57 mkdir -p "${TEMP_BACKUP_DIR}/app"
58 if [[ -d "/opt/myapp" ]]; then
59     sudo rsync -a --exclude 'venv' /opt/myapp/ "${TEMP_BACKUP_DIR}/app/code/"
60 fi
61 if [[ -f "/etc/myapp/myapp.env" ]]; then
62     mkdir -p "${TEMP_BACKUP_DIR}/app/secrets"
63     sudo cp /etc/myapp/myapp.env "${TEMP_BACKUP_DIR}/app/secrets/"
64 fi
65 mkdir -p "${TEMP_BACKUP_DIR}/systemd"
66 if [[ -f "/etc/systemd/system/myapp.service" ]]; then
67     sudo cp /etc/systemd/system/myapp.service "${TEMP_BACKUP_DIR}/systemd/"
68 fi
69
70 # 3. Sao lưu cấu hình Web & TLS (Tang Nginx)
71 mkdir -p "${TEMP_BACKUP_DIR}/web"
72 sudo cp -r /etc/nginx "${TEMP_BACKUP_DIR}/web/nginx_conf"
73 if [[ -d "/var/www" ]]; then
74     sudo cp -r /var/www "${TEMP_BACKUP_DIR}/web/www_data"
75 fi
76 mkdir -p "${TEMP_BACKUP_DIR}/web/ssl"
77 [[ -f "/etc/ssl/certs/lab-selfsigned.crt" ]] && sudo cp /etc/ssl/certs/lab-
selfsigned.crt "${TEMP_BACKUP_DIR}/web/ssl/"
78 [[ -f "/etc/ssl/private/lab-selfsigned.key" ]] && sudo cp /etc/ssl/private/lab-
selfsigned.key "${TEMP_BACKUP_DIR}/web/ssl/"
79
80 # 4. Đóng gói và nén
81 log_msg "INFO" "Đóng gói toàn bộ hệ thống vào file: ${ARCHIVE_FILE}..."
82 sudo tar -czf "$ARCHIVE_FILE" -C "/tmp" "$BACKUP_NAME"
83 sudo chown sysadmin:sysadmin "$ARCHIVE_FILE"
84 sudo rm -rf "$TEMP_BACKUP_DIR"
85 log_msg "INFO" "Tạo bản sao lưu thành công: $(basename "$ARCHIVE_FILE") ($(du -h "
$ARCHIVE_FILE" | cut -f1))"
86
87 # 5. Đóng gói sang VM2 (10.10.10.12)
88 log_msg "INFO" "Đóng gói bản sao lưu sang VM2 (${BACKUP_REMOTE_HOST})..."
89 rsync -avz -e "ssh -o StrictHostKeyChecking=no" "$ARCHIVE_FILE" "${
BACKUP_REMOTE_USER}@${BACKUP_REMOTE_HOST}:${BACKUP_REMOTE_DIR}/"
90 log_msg "INFO" "Đóng gói sang VM2 thành công."
91
92 # 6. Retention (Xóa bản sao lưu cũ hơn 7 ngày)
93 log_msg "INFO" "Đón dẹp bản sao lưu cũ hơn ${BACKUP_RETENTION_DAYS} ngày..."
94 find "$BACKUP_LOCAL_DIR" -name "backup-*.tar.gz" -type f -mtime +"${
BACKUP_RETENTION_DAYS}" -exec rm -f {} \;
95
96 log_msg "INFO" "=== SAO LƯU HOÀN TẤT THÀNH CÔNG ==="
97 send_telegram_alert "[SUCCESS] *[VM1]* Đã sao lưu toàn diện \`${BACKUP_NAME}.tar.gz
\` (MySQL + App + Web + TLS) và đóng gói an toàn sang VM2!"
98

```

2. Script khôi phục thảm họa toàn diện (restore.sh): Thực hiện giải nén gói backup, hoàn nguyên cấu hình Nginx/TLS, mã nguồn ứng dụng, tệp secrets và kích hoạt nạp lại CSDL MySQL:

```

1 #!/usr/bin/env bash
2 # restore.sh - Khôi phục thảm họa toàn diện hệ thống
3 set -euo pipefail
4
5 BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")/.." && pwd)"
6 # shellcheck source=/dev/null
7 source "${BASE_DIR}/config.env"
8 # shellcheck source=/dev/null
9 source "${BASE_DIR}/lib/alert.sh"
10

```

```

11 LOG_FILE="${BASE_DIR}/logs/restore.log"
12 mkdir -p "$(dirname "$LOG_FILE")"
13
14 cleanup_on_err() {
15     local exit_code=$?
16     local line_no=$1
17     local err_msg="[ALERT] [VM1] Khôi phục THAT BAI tai dong ${line_no} (Exit: ${
18     exit_code})"
19     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [FATAL] ${err_msg}" | tee -a "$LOG_FILE"
20     send_telegram_alert "${err_msg}"
21 }
22
23 trap 'cleanup_on_err ${LINENO}' ERR
24
25 log_msg() {
26     local level="$1"
27     local message="$2"
28     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [${level}] ${message}" | tee -a "$LOG_FILE"
29 }
30
31 show_help() {
32     cat << HELP_EOF
33     Su dung: $(basename "$0") [TUY CHON]
34     Tuy chon:
35     -f <duong_dan_file>    Duong dan toi file backup*.tar.gz can khôi phục
36     -l                    Khôi phục tu ban sao lưu MOI NHAT trong /data/backups
37     -h, --help            Hien thi huong dan nay
38     HELP_EOF
39     exit 0
40 }
41
42 TARGET_FILE=""
43 USE_LATEST=0
44
45 for arg in "$@"; do
46     [[ "$arg" == "--help" ]] && show_help
47 done
48
49 while getopts ":f:lh" opt; do
50     case "$opt" in
51         f) TARGET_FILE="$OPTARG" ;;
52         l) USE_LATEST=1 ;;
53         h) show_help ;;
54         \?) echo "[ERROR] Tuy chon khong hop le: -$OPTARG" >&2; exit 1 ;;
55         :) echo "[ERROR] Tuy chon -$OPTARG yeu cau tham so." >&2; exit 1 ;;
56     esac
57 done
58
59 if (( USE_LATEST == 1 )); then
60     TARGET_FILE=$(find "$BACKUP_LOCAL_DIR" -name "backup*.tar.gz" -type f -printf
61     "%T@ %p\n" | sort -n | tail -n 1 | awk '{print $2}')
62 fi
63
64 if [[ -z "$TARGET_FILE" || ! -f "$TARGET_FILE" ]]; then
65     log_msg "ERROR" "Khong tim thay file backup hop le de khôi phục!"
66     exit 1
67 fi
68
69 log_msg "INFO" "=== BAT DAU QUY TRINH KHOI PHUC TOAN DIEN ==="
70 TEMP_RESTORE_DIR="/tmp/restore_$(date '+%Y%m%d_%H%M%S')"
71 mkdir -p "$TEMP_RESTORE_DIR"
72
73 log_msg "INFO" "Dang giai nen goi sao lưu..."
74 tar -xzf "$TARGET_FILE" -C "$TEMP_RESTORE_DIR"
75 UNPACKED_DIR=$(find "$TEMP_RESTORE_DIR" -mindepth 1 -maxdepth 1 -type d | head -n
76 1)
77
78 # 1. Khôi phục tang Nginx & TLS
79 if [[ -d "${UNPACKED_DIR}/web/nginx_conf" ]]; then
80     log_msg "INFO" "Khôi phục cấu hình Nginx..."
81     sudo rsync -a --delete "${UNPACKED_DIR}/web/nginx_conf/" /etc/nginx/
82 fi
83
84 if [[ -d "${UNPACKED_DIR}/web/ssl" ]]; then
85     log_msg "INFO" "Khôi phục chứng chỉ TLS..."
86     [[ -f "${UNPACKED_DIR}/web/ssl/lab-selfsigned.crt" ]] && sudo cp "${
87     UNPACKED_DIR}/web/ssl/lab-selfsigned.crt" /etc/ssl/certs/ && sudo chmod 644 /

```

```

82     etc/ssl/certs/lab-selfsigned.crt
83     [[ -f "${UNPACKED_DIR}/web/ssl/lab-selfsigned.key" ]] && sudo cp "${UNPACKED_DIR}/web/ssl/lab-selfsigned.key" /etc/ssl/private/ && sudo chmod 600 /etc/ssl/private/lab-selfsigned.key
84 fi
85 sudo nginx -t && sudo systemctl reload nginx
86
87 if [[ -d "${UNPACKED_DIR}/web/www_data" ]]; then
88     log_msg "INFO" "Khởi phục nội dung web /var/www..."
89     sudo cp -r "${UNPACKED_DIR}/web/www_data/*" /var/www/
90 fi
91
92 # 2. Khởi phục tang App & Systemd
93 if [[ -d "${UNPACKED_DIR}/app/code" ]]; then
94     log_msg "INFO" "Khởi phục mã nguồn app vào /opt/myapp..."
95     sudo mkdir -p /opt/myapp
96     sudo cp -r "${UNPACKED_DIR}/app/code/*" /opt/myapp/
97     sudo chown -R myapp:myapp /opt/myapp/
98 fi
99 if [[ -f "${UNPACKED_DIR}/app/secrets/myapp.env" ]]; then
100     log_msg "INFO" "Khởi phục file secrets..."
101     sudo mkdir -p /etc/myapp
102     sudo cp "${UNPACKED_DIR}/app/secrets/myapp.env" /etc/myapp/myapp.env
103     sudo chown root:myapp /etc/myapp/myapp.env 2>/dev/null || sudo chown root:root /etc/myapp/myapp.env
104     sudo chmod 640 /etc/myapp/myapp.env
105 fi
106 if [[ -f "${UNPACKED_DIR}/systemd/myapp.service" ]]; then
107     sudo cp "${UNPACKED_DIR}/systemd/myapp.service" /etc/systemd/system/
108     sudo systemctl daemon-reload
109     sudo systemctl restart myapp
110 fi
111
112 # 3. Khởi phục tang CSDL
113 DB_RESTORE_SCRIPT="/home/sysadmin/scripts/scripts_backup_restore_DB/db_restore.sh"
114 SQL_FILE=$(find "${UNPACKED_DIR}/database" -name "*.sql.gz" | head -n 1)
115 if [[ -f "$DB_RESTORE_SCRIPT" && -n "$SQL_FILE" && -f "$SQL_FILE" ]]; then
116     log_msg "INFO" "Kích hoạt script khởi phục CSDL..."
117     sudo bash "$DB_RESTORE_SCRIPT" "$SQL_FILE"
118     log_msg "INFO" "Khởi phục CSDL thành công."
119 else
120     log_msg "WARN" "Không tìm thấy file SQL dump hoặc db_restore.sh để khởi phục CSDL."
121 fi
122 sudo rm -rf "$TEMP_RESTORE_DIR"
123 log_msg "INFO" "=== KHỞI PHỤC TOÀN BỘ HỆ THỐNG THÀNH CÔNG ==="
124 send_telegram_alert "[RESTORE] *[VM1]* Hệ thống đã được khởi phục hoàn chỉnh từ bản sao lưu \"$(basename "$TARGET_FILE")\"!"
125

```

Cấu hình lập lịch tự động hóa bằng Cron

Để tự động hóa hoàn toàn chu trình vận hành, tệp crontab của tài khoản sysadmin trên vm1-svc được cấu hình chạy các script theo chu kỳ:

```

1 # crontab -l
2 TZ=Asia/Ho_Chi_Minh
3
4 # 1. Health-check hệ thống mỗi 5 phút
5 */5 * * * * /home/sysadmin/ops-tool/scripts/healthcheck.sh >/dev/null 2>&1
6
7 # 2. Sao lưu toàn diện & đóng bo sang VM2 lúc 02:00 sáng mỗi ngày
8 0 2 * * * /home/sysadmin/ops-tool/scripts/backup.sh >/dev/null 2>&1
9
10 # 3. Xoay vòng log Nginx lúc 00:00 Chủ Nhật hàng tuần
11 0 0 * * 0 /home/sysadmin/ops-tool/scripts/logrotate.sh -d /var/log/nginx -k 5 >/dev/null 2>&1

```

Diễn tập thực tế khôi phục thảm họa CSDL

Nhóm đã tổ chức diễn tập thực tế tình huống mất mát cơ sở dữ liệu trên máy chủ dịch vụ để chứng minh khả năng phục hồi của script:

1. **Tạo bản sao lưu mới nhất:** Chạy script `db_backup.sh` để đảm bảo có bản lưu trữ mới nhất.
2. **Cố ý phá hủy bảng dữ liệu:** Chạy lệnh hủy bảng dữ liệu đang chạy:

```
1 sudo mysql app_db -e "DROP TABLE items;"
2
```

Truy cập API kiểm thử tại `https://127.0.0.1/api/items` ghi nhận lỗi 500 Internal Server Error (bảng `items` không tồn tại).

3. **Chạy khôi phục:** Chạy script `db_restore.sh`. Tiến trình tự động giải nén và nạp lại dữ liệu SQL.
4. **Kiểm chứng kết quả:** Quét lại bảng và gọi lại API. Kết quả cho thấy danh sách dữ liệu được hồi phục nguyên vẹn 100

5 Tự động hóa

Hệ thống cung cấp một số tập lệnh tự động hóa phục vụ công tác thiết lập tường lửa và kiểm thử bảo mật.

Script cấu hình tường lửa UFW (ufw_setup.sh)

Tập lệnh được đặt tại /root/ufw_setup.sh trên máy vm1-svc:

```
1 #!/usr/bin/env bash
2 # ufw_setup.sh - Cấu hình tường lửa UFW: mac dinh chan vao, chi mo cong can thiet.
3 set -euo pipefail
4 trap 'echo "[LOI] dong $LINENO that bai" >&2' ERR
5
6 SSH_PORT="${1:-22}" # cho phép doi cong SSH khi goi: ./ufw_setup.sh 2222
7
8 echo "[*] Dat chinh sach mac dinh: deny incoming, allow outgoing"
9 ufw default deny incoming
10 ufw default allow outgoing
11
12 echo "[*] Mo cong SSH (${SSH_PORT}/tcp) - quan tri tu xa"
13 ufw allow "${SSH_PORT}/tcp" comment 'SSH quan tri'
14
15 echo "[*] Mo cong 80/tcp (HTTP) - Nginx reverse proxy + vhost trang thai"
16 ufw allow 80/tcp comment 'HTTP Nginx'
17
18 echo "[*] Mo cong 443/tcp (HTTPS) - chi can neu lam diem thuong TLS"
19 ufw allow 443/tcp comment 'HTTPS Nginx TLS'
20
21 # LUU Y: KHONG mo 5432 (PostgreSQL) va KHONG mo 8000 (uvicorn) ra ngoai -
22 # hai dich vu nay chi nghe 127.0.0.1, khong can va khong nen lo ra tuong lua.
23
24 echo "[*] Bat UFW"
25 ufw --force enable
26 ufw status verbose
```

Script mô phỏng dò mật khẩu SSH (simulate_ssh_bruteforce.sh)

Tập lệnh chạy từ máy vm2-backup hoặc máy Host để kiểm thử fail2ban trên vm1-svc:

```
1 #!/usr/bin/env bash
2 # simulate_ssh_bruteforce.sh - Mo phong do mat khau SSH TU MAY KHAC (VM2 hoac host)
3 # de kich hoat fail2ban ban truc tiep luc demo.
4 set -euo pipefail
5
6 TARGET_HOST="${1:?Can truyen IP cua VM1, vd: ./simulate_ssh_bruteforce.sh 192.168.56.10}"
7 TARGET_PORT="${2:-22}"
8
9 echo "[*] Thu SSH sai mat khau 4 lan vao ${TARGET_HOST}:${TARGET_PORT} de kich hoat
10 fail2ban..."
11 for i in 1 2 3 4; do
12     echo "    -> lan $i"
13     sshpass -p "matkhau-sai-co-y-$i" ssh -p "${TARGET_PORT}" \
14         -o StrictHostKeyChecking=no -o ConnectTimeout=3 \
15         fake_user@"${TARGET_HOST}" exit || true
16     sleep 1
17 done
18
19 echo "[*] Tren VM1, kiem tra ban bang:"
20 echo "    sudo fail2ban-client status sshd"
```

Các script tự động hóa khác trong hệ thống

Bên cạnh các script sao lưu và khôi phục, bộ công cụ vận hành ops-tool còn phát triển các tập lệnh tự động hóa phục vụ giám sát, triển khai an toàn và dọn dẹp hệ thống.

Thư viện gửi cảnh báo Telegram (lib/alert.sh)

Thư viện cung cấp hàm gửi tin nhắn về điện thoại thông qua Telegram Bot API:

```

1 #!/usr/bin/env bash
2 # alert.sh - Thư viện gửi cảnh báo Telegram
3 set -euo pipefail
4
5 send_telegram_alert() {
6     local message="$1"
7     if [[ -z "${TELEGRAM_BOT_TOKEN:-}" || -z "${TELEGRAM_CHAT_ID:-}" ]]; then
8         echo "[ERROR] Telegram token hoặc Chat ID chưa được cấu hình." >&2
9         return 1
10    fi
11    local url="https://api.telegram.org/bot${TELEGRAM_BOT_TOKEN}/sendMessage"
12    if ! curl -fsS -X POST "$url" \
13        --data-urlencode "chat_id=${TELEGRAM_CHAT_ID}" \
14        --data-urlencode "text=${message}" \
15        > /dev/null; then
16        echo "[ERROR] Không thể gửi Telegram alert." >&2
17        return 1
18    fi
19 }

```

Script giám sát sức khỏe hệ thống và dịch vụ (healthcheck.sh)

Tự động thu thập phần trăm sử dụng CPU, RAM, Disk dung lượng phân vùng / và /data. Kiểm tra trạng thái hoạt động của 3 dịch vụ chính (nginx, mysql, myapp) và 4 cổng lắng nghe tương ứng. Quét phản hồi từ đầu-cuối của chuỗi Web → App → DB qua endpoint /health:

```

1 #!/usr/bin/env bash
2 # healthcheck.sh - Giám sát hệ thống và gửi cảnh báo Telegram
3 set -euo pipefail
4
5 BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")/.." && pwd)"
6 # shellcheck source=/dev/null
7 source "${BASE_DIR}/config.env"
8 # shellcheck source=/dev/null
9 source "${BASE_DIR}/lib/alert.sh"
10
11 LOG_FILE="${BASE_DIR}/logs/healthcheck.log"
12 mkdir -p "$(dirname "$LOG_FILE")"
13
14 cleanup_on_err() {
15     local exit_code=$?
16     local line_no=$1
17     echo "[$(date +%Y-%m-%d %H:%M:%S)] [FATAL] Script gặp lỗi tại dòng ${line_no} với mã thoát ${exit_code}" | tee -a "$LOG_FILE"
18 }
19 trap 'cleanup_on_err ${LINENO}' ERR
20
21 log_msg() {
22     local level="$1"
23     local message="$2"
24     echo "[$(date +%Y-%m-%d %H:%M:%S)] [$level] ${message}" | tee -a "$LOG_FILE"
25 }
26
27 has_issues=0
28 alert_body=""
29
30 check_disk() {
31     local mount_point="$1"
32     if mountpoint -q "$mount_point" || [[ "$mount_point" == "/" ]]; then
33         local usage
34         usage=$(df -P "$mount_point" | awk 'NR==2 {print $5}' | tr -d '%')
35         if (( usage >= THRESHOLD_DISK )); then
36             local issue="[WARN] Ổ đĩa ${mount_point} vượt ngưỡng: ${usage}% (Ngưỡng: ${THRESHOLD_DISK}%)"
37             log_msg "WARN" "$issue"
38             alert_body+="${issue}\n"
39             has_issues=1

```

```

40         else
41             log_msg "INFO" "0 dia ${mount_point} binh thuong: ${usage}%"
42         fi
43     fi
44 }
45
46 check_ram() {
47     local ram_usage
48     ram_usage=$(free | awk '/Mem:/ {printf "%.0f", ($3/$2)*100}')
49     if (( ram_usage >= THRESHOLD_RAM )); then
50         local issue="[WARN] RAM vuot nguong: ${ram_usage}% (Nguong: ${THRESHOLD_RAM}%)"
51         log_msg "WARN" "$issue"
52         alert_body+="${issue}\n"
53         has_issues=1
54     else
55         log_msg "INFO" "RAM binh thuong: ${ram_usage}%"
56     fi
57 }
58
59 check_cpu() {
60     local cpu_idle
61     cpu_idle=$(top -bn1 | grep "Cpu(s)" | sed "s/.*, *\([0-9.*\)]\)%* id.*\/\1/" | awk '{
62         print int($1)}')
63     local cpu_usage=$(( 100 - cpu_idle ))
64     if (( cpu_usage >= THRESHOLD_CPU )); then
65         local issue="[WARN] CPU vuot nguong: ${cpu_usage}% (Nguong: ${THRESHOLD_CPU}%)"
66         log_msg "WARN" "$issue"
67         alert_body+="${issue}\n"
68         has_issues=1
69     else
70         log_msg "INFO" "CPU binh thuong: ${cpu_usage}%"
71     fi
72 }
73
74 check_service() {
75     local svc="$1"
76     if systemctl is-active --quiet "$svc"; then
77         log_msg "INFO" "Dich vu ${svc}: RUNNING"
78     else
79         local issue="[ALERT] Dich vu ${svc} dang BI DUNG!"
80         log_msg "ERROR" "$issue"
81         alert_body+="${issue}\n"
82         has_issues=1
83     fi
84 }
85
86 check_port() {
87     local port="$1"
88     local desc="$2"
89     if ss -tulpn | grep -q ":${port} "; then
90         log_msg "INFO" "Cong ${port} (${desc}): Dang lang nghe"
91     else
92         local issue="[ALERT] Cong ${port} (${desc}) KHONG phan hoi!"
93         log_msg "ERROR" "$issue"
94         alert_body+="${issue}\n"
95         has_issues=1
96     fi
97 }
98
99 check_http_endpoint() {
100     local endpoint_url="https://127.0.0.1/health"
101     local host_header="app.lab.local"
102     local response
103     if response=$(curl -k -fsS -H "Host: ${host_header}" "${endpoint_url}" 2>/dev/null);
104     then
105         log_msg "INFO" "Endpoint /health phan hoi tot: ${response}"
106     else
107         local issue="[ALERT] Endpoint HTTPS /health khong phan hoi hoac tra ve loi!"
108         log_msg "ERROR" "$issue"
109         alert_body+="${issue}\n"
110         has_issues=1
111     fi
112 }
113
114 log_msg "INFO" "=== BAT DAU HEALTH CHECK ==="
115 check_disk "/"

```

```

114 check_disk "/data"
115 check_ram
116 check_cpu
117 check_service "nginx"
118 check_service "mysql"
119 check_service "myapp"
120 check_port "80" "HTTP Nginx"
121 check_port "443" "HTTPS Nginx"
122 check_port "8000" "Gunicorn App"
123 check_port "3306" "MySQL"
124 check_http_endpoint
125
126 if (( has_issues == 1 )); then
127     full_alert="[ALERT] [VM1 - HEALTH CHECK ALERT] Phát hiện sự cố:\n\n$(echo -e "
128     $alert_body)"
129     send_telegram_alert "$full_alert"
130     log_msg "WARN" "Đã gửi cảnh báo sự cố về Telegram."
131 else
132     log_msg "INFO" "Tất cả các thành phần hệ thống hoạt động bình thường."
133 fi
134 log_msg "INFO" "=== HOÀN TẤT HEALTH CHECK ==="

```

Script triển khai an toàn có tự động Rollback (deploy.sh)

Thực hiện triển khai Nginx cấu hình hoặc mã nguồn ứng dụng một cách an toàn. Tạo bản backup tạm thời; nếu kiểm tra lỗi cú pháp (nginx -t) thất bại hoặc probe endpoint trả mã lỗi, script tự động hoàn nguyên (Rollback) dữ liệu qua rsync và gửi cảnh báo về Telegram:

```

1  #!/usr/bin/env bash
2  # deploy.sh - Triển khai an toàn có tự động Rollback
3  set -euo pipefail
4
5  BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")/.." && pwd)"
6  # shellcheck source=/dev/null
7  source "${BASE_DIR}/config.env"
8  # shellcheck source=/dev/null
9  source "${BASE_DIR}/lib/alert.sh"
10
11 LOG_FILE="${BASE_DIR}/logs/deploy.log"
12 mkdir -p "$(dirname "$LOG_FILE")"
13
14 ROLLBACK_DIR="/tmp/deploy_backup_$(date +%Y%m%d_%H%M%S)"
15 APP_TARGET_DIR="/opt/myapp"
16
17 log_msg() {
18     local level="$1"
19     local message="$2"
20     echo "[$(date +%Y-%m-%d %H:%M:%S)] [$level] $message" | tee -a "$LOG_FILE"
21 }
22
23 perform_rollback() {
24     trap - ERR
25     log_msg "WARN" "[WARN] Phát hiện sự cố! Bắt đầu quy trình Rollback tự động..."
26     if [[ -d "${ROLLBACK_DIR}/nginx" ]]; then
27         sudo rsync -a --delete "${ROLLBACK_DIR}/nginx/" /etc/nginx/
28         sudo systemctl reload nginx || sudo systemctl restart nginx
29         log_msg "INFO" "Đã hoàn nguyên cấu hình Nginx về trạng thái an toàn."
30     fi
31     if [[ -d "${ROLLBACK_DIR}/app" ]]; then
32         sudo rsync -a --delete "${ROLLBACK_DIR}/app/" "${APP_TARGET_DIR}/"
33         sudo chown -R myapp:myapp "${APP_TARGET_DIR}"
34         sudo systemctl restart myapp || true
35         log_msg "INFO" "Đã hoàn nguyên mã nguồn App về phiên bản an toàn."
36     fi
37     sudo rm -rf "$ROLLBACK_DIR"
38     local alert="[ALERT] [VM1] Deploy THAT BAI! Hệ thống đã tự động ROLLBACK về phiên bản an toàn gần nhất."
39     send_telegram_alert "$alert"
40     log_msg "ERROR" "Rollback hoàn tất. Đã gửi cảnh báo Telegram."
41     exit 1
42 }

```



```

43 cleanup_on_err() {
44     local exit_code=$?
45     local line_no=$1
46     log_msg "FATAL" "Deploy that bai tai dong ${line_no} (Exit: ${exit_code})"
47     perform_rollback
48 }
49
50 trap 'cleanup_on_err ${LINENO}' ERR
51
52 show_help() {
53     cat << HELP_EOF
54     Su dung: ${basename "$0"} [TUY CHON]
55     Tuy chon:
56     -s <duong_dan>      Thu muc chua ma nguon/cau hinh moi can deploy
57     -t <loai>           Loai deploy: 'nginx' hoac 'app' (Mac dinh: nginx)
58     -h, --help         Hien thi huong dan nay
59     HELP_EOF
60     exit 0
61 }
62
63 SRC_DIR=""
64 DEPLOY_TYPE="nginx"
65
66 for arg in "$@"; do
67     [[ "$arg" == "--help" ]] && show_help
68 done
69
70 while getopts ":s:t:h" opt; do
71     case "$opt" in
72         s) SRC_DIR="$OPTARG" ;;
73         t) DEPLOY_TYPE="$OPTARG" ;;
74         h) show_help ;;
75         \?) echo "[ERROR] Tuy chon khong hop le: -$OPTARG" >&2; exit 1 ;;
76         :) echo "[ERROR] Tuy chon -$OPTARG yeu cau tham so." >&2; exit 1 ;;
77     esac
78 done
79
80 if [[ -z "$SRC_DIR" || ! -d "$SRC_DIR" ]]; then
81     log_msg "ERROR" "Thu muc nguon (-s) khong hop le hoac khong ton tai!"
82     exit 1
83 fi
84
85 log_msg "INFO" "=== BAT DAU QUY TRINH DEPLOY (${DEPLOY_TYPE^^}) ==="
86
87 if [[ "$DEPLOY_TYPE" == "nginx" ]]; then
88     sudo mkdir -p "${ROLLBACK_DIR}/nginx"
89     sudo rsync -a /etc/nginx/ "${ROLLBACK_DIR}/nginx/"
90
91     log_msg "INFO" "Sao chep cau hinh moi vao /etc/nginx/..."
92     sudo cp -r "${SRC_DIR}/*" /etc/nginx/
93     sudo chown -R root:root /etc/nginx
94     sudo find /etc/nginx -type f -exec chmod 644 {} \;
95     sudo find /etc/nginx -type d -exec chmod 755 {} \;
96
97     log_msg "INFO" "Kiem tra cu phap cau hinh (nginx -t)..."
98     sudo nginx -t
99     log_msg "INFO" "Tai nap dich vu Nginx..."
100    sudo systemctl reload nginx
101    log_msg "INFO" "Xac nhan dich vu Nginx dang chay..."
102    sudo systemctl is-active --quiet nginx
103
104 elif [[ "$DEPLOY_TYPE" == "app" ]]; then
105     sudo mkdir -p "${ROLLBACK_DIR}/app"
106     sudo rsync -a "${APP_TARGET_DIR}/" "${ROLLBACK_DIR}/app/"
107
108     log_msg "INFO" "Sao chep ma nguon app moi vao ${APP_TARGET_DIR}..."
109     sudo cp -r "${SRC_DIR}/*" "${APP_TARGET_DIR}/"
110     sudo chown -R myapp:myapp "${APP_TARGET_DIR}"
111
112     log_msg "INFO" "Khoi dong lai dich vu myapp..."
113     sudo systemctl restart myapp
114     sleep 2
115
116     log_msg "INFO" "Kiem tra phan hoi endpoint /health..."
117     curl -k -fsS -H "Host: app.lab.local" https://127.0.0.1/health > /dev/null
118 fi

```

```

119
120 sudo rm -rf "$ROLLBACK_DIR"
121 log_msg "INFO" "=== DEPLOY THANH CONG ==="
122 send_telegram_alert "[DEPLOY] *[VM1]* Deploy \'${DEPLOY_TYPE}\' thanh cong!"

```

Script xoay vòng và nén nhật ký (logrotate.sh)

Thực hiện nén tệp .log cũ sang định dạng .gz kèm dấu thời gian để giải phóng dung lượng đĩa, sau đó gửi tín hiệu reopen tới Nginx để tiếp tục ghi vào file log mới mà không làm sập web server:

```

1  #!/usr/bin/env bash
2  # logrotate.sh - Xoay vong va nen nhat ky he thong
3  set -euo pipefail
4
5  BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")/.." && pwd)"
6  # shellcheck source=/dev/null
7  source "${BASE_DIR}/config.env"
8  # shellcheck source=/dev/null
9  source "${BASE_DIR}/lib/alert.sh"
10
11 LOG_FILE="${BASE_DIR}/logs/logrotate.log"
12 mkdir -p "$(dirname "$LOG_FILE")"
13
14 TARGET_DIR="/var/log/nginx"
15 KEEP_GENERATIONS=5
16
17 cleanup_on_err() {
18     local exit_code=$?
19     local line_no=$1
20     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [FATAL] logrotate.sh loi tai dong ${line_no} (
21     Exit: ${exit_code})" | tee -a "$LOG_FILE"
22 }
23 trap 'cleanup_on_err ${LINENO}' ERR
24
25 log_msg() {
26     local level="$1"
27     local message="$2"
28     echo "[$(date '+%Y-%m-%d %H:%M:%S')] [${level}] ${message}" | tee -a "$LOG_FILE"
29 }
30
31 show_help() {
32     cat << HELP_EOF
33     Su dung: $(basename "$0") [TUY CHON]
34     Tuy chon:
35     -d <duong_dan>      Thu muc chua log can xoay (Mac dinh: /var/log/nginx)
36     -k <so_luong>       So luong the he log luu giu (Mac dinh: 5)
37     -h, --help          Hien thi huong dan nay
38     HELP_EOF
39     exit 0
40 }
41
42 for arg in "$@"; do
43     [[ "$arg" == "--help" ]] && show_help
44 done
45
46 while getopts ":d:k:h" opt; do
47     case "$opt" in
48         d) TARGET_DIR="$OPTARG" ;;
49         k) KEEP_GENERATIONS="$OPTARG" ;;
50         h) show_help ;;
51         \?) echo "[ERROR] Tuy chon khong hop le: -$OPTARG" >&2; exit 1 ;;
52         :) echo "[ERROR] Tuy chon -$OPTARG yeu cau tham so." >&2; exit 1 ;;
53     esac
54 done
55
56 log_msg "INFO" "=== BAT DAU XOAY VONG LOG ==="
57 if [[ ! -d "$TARGET_DIR" ]]; then
58     log_msg "ERROR" "Thu muc ${TARGET_DIR} khong ton tai!"
59     exit 1
60 fi
61
62 TIMESTAMP="$(date '+%Y%m%d_%H%M%S')"

```

```

62
63 for raw_log in "${TARGET_DIR}/*.log; do
64     [[ -e "$raw_log" ]] || continue
65     filename="$(basename "$raw_log")"
66     rotated_name="${raw_log}.${TIMESTAMP}"
67
68     sudo mv "$raw_log" "$rotated_name"
69     sudo gzip "$rotated_name"
70     log_msg "INFO" "Da xoay va nen: ${filename} -> ${filename}.${TIMESTAMP}.gz"
71 done
72
73 if systemctl is-active --quiet nginx; then
74     sudo nginx -s reopen || sudo systemctl reload nginx
75     log_msg "INFO" "Da gui tin hieu reopen log toi Nginx."
76 fi
77
78 for base_file in "${TARGET_DIR}/*.log; do
79     base_name="$(basename "$base_file")"
80     mapfile -t old_logs < <(find "$TARGET_DIR" -maxdepth 1 -name "${base_name}.*.gz" -
81     type f -printf "%T@ %p\n" | sort -nr | awk '{print $2}')
82     total_files="${#old_logs[@]}"
83     if (( total_files > KEEP_GENERATIONS )); then
84         files_to_delete=( "${old_logs[@]:KEEP_GENERATIONS}" )
85         for file in "${files_to_delete[@]}; do
86             sudo rm -f "$file"
87             log_msg "INFO" "Da don dep log cu vuot moc: $(basename "$file")"
88         done
89     fi
90 done
log_msg "INFO" "=== HOAN TAT XOAY VONG LOG ==="

```

Menu CLI điều phối tương tác hệ thống (main.sh)

Cung cấp giao diện tương tác dòng lệnh để quản trị viên dễ dàng kích hoạt các tác vụ:

```

1 #!/usr/bin/env bash
2 # main.sh - Menu CLI tương tác điều phối vận hành
3 set -euo pipefail
4
5 BASE_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")" && pwd)"
6 # shellcheck source=/dev/null
7 source "${BASE_DIR}/config.env"
8 # shellcheck source=/dev/null
9 source "${BASE_DIR}/lib/alert.sh"
10
11 show_menu() {
12     clear
13     echo "=====
14     echo "      HE THONG VAN HANH & TU DONG HOA LINUX (VM1)          "
15     echo "=====
16     echo " 1) Kiem tra suc khoe he thong (Health-check)"
17     echo " 2) Sao luu toan dien (Backup & Rsync VM2)"
18     echo " 3) Khoi phuc he thong (Restore tu ban moi nhat)"
19     echo " 4) Xoay vong va nen nhat ky (Logrotate)"
20     echo " 5) Trien khai thu nghiem (Deploy Nginx/App)"
21     echo " 6) Gui canh bao thu nghiem toi Telegram"
22     echo " 7) Kiem tra cu phap toan bo Script (ShellCheck)"
23     echo " 0) Thoat (Exit)"
24     echo "-----"
25 }
26
27 pause() {
28     echo ""
29     read -rp "Nhan [Enter] de quay lai Menu..."
30 }
31
32 while true; do
33     show_menu
34     read -rp "Vui long chon chuc nang [0-7]: " choice
35     case "$choice" in
36         1)
37             echo -e "\n>>> Dang chay Health-check..."
38             "${BASE_DIR}/scripts/healthcheck.sh" || true
39             pause ;;

```

```

40      2)
41          echo -e "\n>>> Dang chay Backup & Rsync sang VM2..."
42          "${BASE_DIR}/scripts/backup.sh" || true
43          pause ;;
44      3)
45          echo -e "\n>>> Dang khoi phuc tu ban sao luu gan nhat..."
46          "${BASE_DIR}/scripts/restore.sh" -1 || true
47          pause ;;
48      4)
49          echo -e "\n>>> Dang xoay vong log Nginx..."
50          "${BASE_DIR}/scripts/logrotate.sh" -d /var/log/nginx -k 5 || true
51          pause ;;
52      5)
53          echo -e "\n>>> TRIEN KHAI AN TOAN (DEPLOY)"
54          read -rp "Nhap duong dan thu muc nguon (-s): " custom_path
55          read -rp "Nhap loai deploy ('nginx' hoac 'app'): " dep_type
56          if [[ -d "$custom_path" ]]; then
57              "${BASE_DIR}/scripts/deploy.sh" -s "$custom_path" -t "$dep_type" || true
58          else
59              echo "[ERROR] Thu muc khong ton tai!"
60          fi
61          pause ;;
62      6)
63          echo -e "\n>>> Dang gui tin nhan thu nghiem toi Telegram..."
64          send_telegram_alert "Gui canh bao thu cong tu Menu CLI van hanh!"
65          echo "[OK] Da gui tin nhan."
66          pause ;;
67      7)
68          echo -e "\n>>> Dang kiem tra ma nguon bang ShellCheck..."
69          if command -v shellcheck >/dev/null 2>&1; then
70              shellcheck "${BASE_DIR}/main.sh" "${BASE_DIR}/scripts/*.sh" "${BASE_DIR}/
71          /lib/*.sh && echo "Tat ca script deu dat chuan ShellCheck 100% sach loi!" || true
72          else
73              echo "[!] Chua cai dat shellcheck."
74          fi
75          pause ;;
76      0)
77          echo -e "\nThoat khoi chuong trinh. Tam biet!"
78          exit 0 ;;
79      *)
80          echo -e "\n[Loi] Lua chon khong hop le!"
81          sleep 2 ;;
82  esac
done

```

Kịch bản kiểm thử các tính năng tự động hóa

Nhóm đã triển khai kiểm thử các kịch bản thực tế để nghiệm thu hệ thống:

- **Kiểm thử ShellCheck tĩnh:** Toàn bộ các script tự động hóa được kiểm thử qua công cụ ShellCheck. Lệnh kiểm thử `shellcheck /home/sysadmin/ops-tool/main.sh ...` cho kết quả sạch lỗi 100% (không phát sinh cảnh báo).
- **Kiểm thử kích hoạt báo động Telegram:**
 1. *Dừng dịch vụ myapp:* Sử dụng lệnh `sudo systemctl stop myapp`. Chạy healthcheck, hệ thống ngay lập tức gửi thông điệp [ALERT] Dịch vụ myapp đang BỊ DỪNG! về Telegram của quản trị viên.
 2. *Stress CPU vượt ngưỡng 80%:* Sử dụng `stress-ng -cpu 0 -timeout 30s` để đẩy CPU tải cao. Healthcheck ghi nhận và bắn ngay cảnh báo đỏ [WARN] CPU vượt ngưỡng về Telegram.
- **Kiểm thử deploy an toàn lỗi và rollback:**
 1. Sao chép cấu hình Nginx lỗi chứa dòng từ khóa vô nghĩa `abcdef`. Kích hoạt deploy:

```
1 ./scripts/deploy.sh -s /home/sysadmin/ops-tool/nginx_temp/  
  nginx_wrong -t nginx  
2
```

2. Tiến trình chạy `nginx -t` báo lỗi cú pháp. Script bắt tín hiệu `ERR`, lập tức dọn dẹp thư mục cấu hình lỗi và đồng bộ ngược cấu hình từ thư mục backup `/tmp/deploy_backup_*` để cứu hệ thống. Dịch vụ Nginx vẫn được giữ ở trạng thái `active (running)`. Telegram nhận tin nhắn báo động deploy thất bại và đã rollback an toàn.

6 Điểm thưởng TLS / HTTPS

Lập luận khoa học về chứng chỉ tự ký trên môi trường Lab

Trong môi trường phòng Lab cô lập (Internal network hoặc Host-Only network), việc triển khai chứng chỉ TLS cấp bởi tổ chức Let's Encrypt hoặc các CA công cộng là không khả thi vì các lý do sau:

- **Cơ chế xác thực tên miền của Let's Encrypt (ACME Challenge):** Để cấp phát chứng chỉ, máy chủ Let's Encrypt cần truy cập ngược lại máy chủ dịch vụ của chúng ta qua Internet công cộng trên cổng 80 (HTTP-01 challenge) hoặc cổng 443 nhằm xác thực quyền sở hữu tên miền.
- **Thiếu IP và tên miền công khai:** Các máy ảo trong phòng Lab sử dụng dải IP nội bộ và tên miền giả lập (app.lab.local), không thể được phân giải bởi các máy chủ DNS công cộng toàn cầu và Let's Encrypt không thể kết nối tới các IP riêng tư này.

Do đó, phương án triển khai tối ưu và khả thi duy nhất ở đây là tạo một **Chứng chỉ tự ký (Self-signed Certificate)** hoặc một **Internal CA** để tự ký cho tên miền nội bộ.

Các bước tạo chứng chỉ tự ký và cấu hình Nginx

1. Tạo cặp khóa và chứng chỉ tự ký có hiệu lực 1 năm thông qua OpenSSL:

```
1 sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \  
2 -keyout /etc/ssl/private/lab-selfsigned.key \  
3 -out /etc/ssl/certs/lab-selfsigned.crt \  
4 -subj "/C=VN/ST=HCMC/O=HCMUS-Lab/CN=app.lab.local" \  
5
```

2. Phân quyền bảo mật cho tệp khóa và chứng chỉ:

```
1 sudo chmod 600 /etc/ssl/private/lab-selfsigned.key \  
2 sudo chmod 644 /etc/ssl/certs/lab-selfsigned.crt \  
3
```

3. Cấu hình Nginx (app.conf) phục vụ giao thức HTTPS trên cổng 443 và tự động chuyển hướng (Redirect) toàn bộ lưu lượng HTTP ở cổng 80 sang HTTPS:

```
1 # /etc/nginx/sites-available/app.conf \  
2 # Cấu hình Redirect từ HTTP sang HTTPS \  
3 server { \  
4     listen 80; \  
5     server_name app.lab.local; \  
6     return 301 https://$host$request_uri; \  
7 } \  
8 \  
9 # Cấu hình HTTPS \  
10 server { \  
11     listen 443 ssl; \  
12     server_name app.lab.local; \  
13 \  
14     ssl_certificate /etc/ssl/certs/lab-selfsigned.crt; \  
15     ssl_certificate_key /etc/ssl/private/lab-selfsigned.key; \  
16 \  
17     # Các thông số mã hóa bảo mật khuyến nghị \  
18     ssl_protocols TLSv1.2 TLSv1.3; \  
19     ssl_ciphers HIGH:!aNULL:!MD5; \  
20 \  
21     access_log /var/log/nginx/app.access.log; \  
22     error_log /var/log/nginx/app.error.log; \  
23
```

```
24     location / {
25         proxy_pass http://127.0.0.1:8000;
26         proxy_set_header Host $host;
27         proxy_set_header X-Real-IP $remote_addr;
28         proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
29         proxy_set_header X-Forwarded-Proto $scheme;
30     }
31 }
```

4. Mở cổng HTTPS trên tường lửa UFW và khởi động lại dịch vụ:

```
1 sudo ufw allow 443/tcp comment 'HTTPS Nginx TLS'
2 sudo nginx -t
3 sudo systemctl reload nginx
4
```

7 Nhìn lại

Bài học từ sự cố cloud-init

Trong quá trình triển khai cấu hình gia cố SSH, nhóm đã gặp sự cố nghiêm trọng khi tệp `sshd_config` đã tắt mật khẩu nhưng khi kiểm tra thực tế bằng lệnh `sshd -T` vẫn hiển thị `passwordauthentication yes`.

Qua tìm hiểu thực tế, nguyên nhân là do cơ chế ghi đè của `cloud-init` trên hạ tầng ảo hóa. Bài học rút ra là:

- Luôn kiểm tra các giá trị cấu hình thực tế đang chạy của hệ thống thông qua các công cụ động (`sshd -T`, `sysctl -a`, v.v.) thay vì chỉ tin tưởng vào nội dung các file cấu hình tĩnh.
- Hiểu rõ cơ chế nạp file cấu hình theo thứ tự ưu tiên của HDH Linux (thư mục `con.d/` ghi đè cấu hình tệp chính).

Kế hoạch cải tiến và Bài học khác

Trong quá trình phát triển và hoàn thiện hệ thống, nhóm đã gặp một số sự cố kỹ thuật thực tế và rút ra các bài học kinh nghiệm sâu sắc:

1. Sự cố thiếu quyền PROCESS khi chạy mysqldump:

- *Hiện tượng:* Lệnh sao lưu trả về lỗi `Access denied; you need (at least one of) the PROCESS privilege(s) for this operation`.
- *Nguyên nhân:* MySQL 8.0 mặc định yêu cầu quyền PROCESS toàn cục để kết xuất thông tin tablespace, trong khi tài khoản `app_user` chỉ được cấp quyền tối thiểu trên schema `app_db` của ứng dụng.
- *Giải pháp:* Thêm cờ `-no-tablespaces` vào câu lệnh `mysqldump` để chỉ tập trung sao lưu cấu trúc và dữ liệu bảng mà không cần dump tới tablespace hệ thống.

2. Cảnh báo an toàn mật khẩu MySQL trên dòng lệnh:

- *Hiện tượng:* Xuất hiện cảnh báo `Using a password on the command line interface can be insecure`.
- *Nguyên nhân:* Truyền mật khẩu trực tiếp qua cờ `-p` làm lộ thông tin nhạy cảm trong bảng tiến trình `ps aux`.
- *Giải pháp:* Sử dụng biến môi trường nội bộ `MYSQL_PWD` để che giấu mật khẩu an toàn khi gọi lệnh.

3. Sự cố lỗi LOCK TABLES khi sao lưu:

- *Hiện tượng:* `mysqldump` trả lỗi `Error 1044: Access denied` khi cố gắng khóa các bảng dữ liệu để sao lưu.
- *Nguyên nhân:* Quyền tối thiểu của `app_user` không bao gồm quyền khóa bảng hệ thống.
- *Giải pháp:* Bổ sung cờ `-single-transaction -skip-lock-tables` vào câu lệnh dump để tạo transaction snapshot an toàn mà không cần khóa bảng gây gián đoạn hoạt động của ứng dụng.

4. Sự cố lỗi phân quyền Error 1142 khi chạy khôi phục:

- *Hiện tượng*: Khôi phục CSDL bằng script `db_restore.sh` dưới quyền `app_user` bị từ chối.
- *Nguyên nhân*: File sao lưu chứa các câu lệnh quản trị như `DROP TABLE IF EXISTS` trước khi tạo bảng, vượt quá quyền hạn tối thiểu được cấp cho `app_user`.
- *Giải pháp*: Chuyển đổi lệnh khôi phục thảm họa (vốn là tác vụ của quản trị viên) sang thực thi dưới quyền `sudo mysql`.

5. Sự cố từ chối quyền truy cập (Permission Denied) khi đóng gói:

- *Hiện tượng*: Tiến trình sao lưu toàn diện `backup.sh` báo lỗi không thể nén file `secrets` và file chứng chỉ TLS.
- *Nguyên nhân*: Các file nhạy cảm như `myapp.env` (quyền 640) và các TLS private key (quyền 600) chỉ cho phép nhóm dịch vụ và root đọc, user thường `sysadmin` không có quyền truy cập trực tiếp.
- *Giải pháp*: Sử dụng `sudo tar -czf` để đóng gói và ngay sau đó gọi `sudo chown sysadmin:sysadmin` trên tệp nén `.tar.gz` để lệnh `rsync` có thể gửi tệp đi một cách bình thường.

6. Sai lệch đường dẫn thư mục mã nguồn ứng dụng:

- *Hiện tượng*: Tiến trình deploy và sao lưu trở nhầm vào thư mục mã nguồn phát triển ban đầu của dev.
- *Giải pháp*: Đồng bộ và quy hoạch toàn bộ tiến trình triển khai, sao lưu và phục hồi về đúng thư mục vận hành chính thức `/opt/myapp` với quyền sở hữu chuẩn `myapp:myapp` theo đúng khai báo trong `myapp.service`.